

REPORTE TÉCNICO

Implementación de una Arquitectura Segura en Microsoft Azure para Clínica FEI+

1. Introducción

Clínica FEI+ es una organización de atención médica con cuatro sedes ubicadas en el estado de Veracruz. Como resultado de una auditoría de seguridad de la información, se identificaron tres hallazgos críticos:

1. Transmisión de expedientes clínicos sin cifrado entre sedes.
2. Ausencia de mecanismos de auditoría que permitan determinar quién accede a la información y qué modificaciones realiza.
3. Acceso a estudios médicos sin autenticación adecuada.

Adicionalmente, la infraestructura existente dependía de un servidor físico con más de nueve años de antigüedad, respaldos manuales y mecanismos inseguros de intercambio de información con aseguradoras.

Con el objetivo de mitigar estos riesgos, se diseñó e implementó una arquitectura basada en servicios de Microsoft Azure que proporciona controles de seguridad, trazabilidad, disponibilidad y cumplimiento regulatorio.

2. Objetivos

Objetivo General

Diseñar e implementar una arquitectura segura en la nube que permita proteger los expedientes clínicos, garantizar la trazabilidad de los accesos y mejorar la continuidad operativa de Clínica FEI+.

Objetivos Específicos

- Proteger los datos clínicos mediante mecanismos de cifrado.
- Implementar autenticación multifactor y control de acceso basado en roles.
- Centralizar los registros de auditoría.

- Establecer mecanismos seguros para compartir información con aseguradoras.
 - Eliminar los puntos únicos de falla presentes en la infraestructura actual.
 - Cumplir con los requisitos establecidos por la aseguradora y las regulaciones aplicables.
-

3. Análisis de Riesgos

Activos Críticos

Activo	Importancia
Expedientes clínicos	Información médica sensible
Estudios e imágenes médicas	Soporte para diagnósticos
Sistema de expedientes	Operación principal de la clínica
Sistema de citas	Continuidad operativa
Credenciales de usuarios	Control de acceso
Infraestructura tecnológica	Disponibilidad de servicios

Amenazas Identificadas

- Robo de información médica.
- Acceso no autorizado.
- Ransomware.
- Compromiso de credenciales.
- Intercepción de comunicaciones.
- Falla de infraestructura.
- Error humano.

Vulnerabilidades Detectadas

- Datos transmitidos sin cifrado.
- Falta de registros de auditoría.
- Acceso libre a estudios clínicos.
- FTP con credenciales compartidas.
- Servidor físico obsoleto.

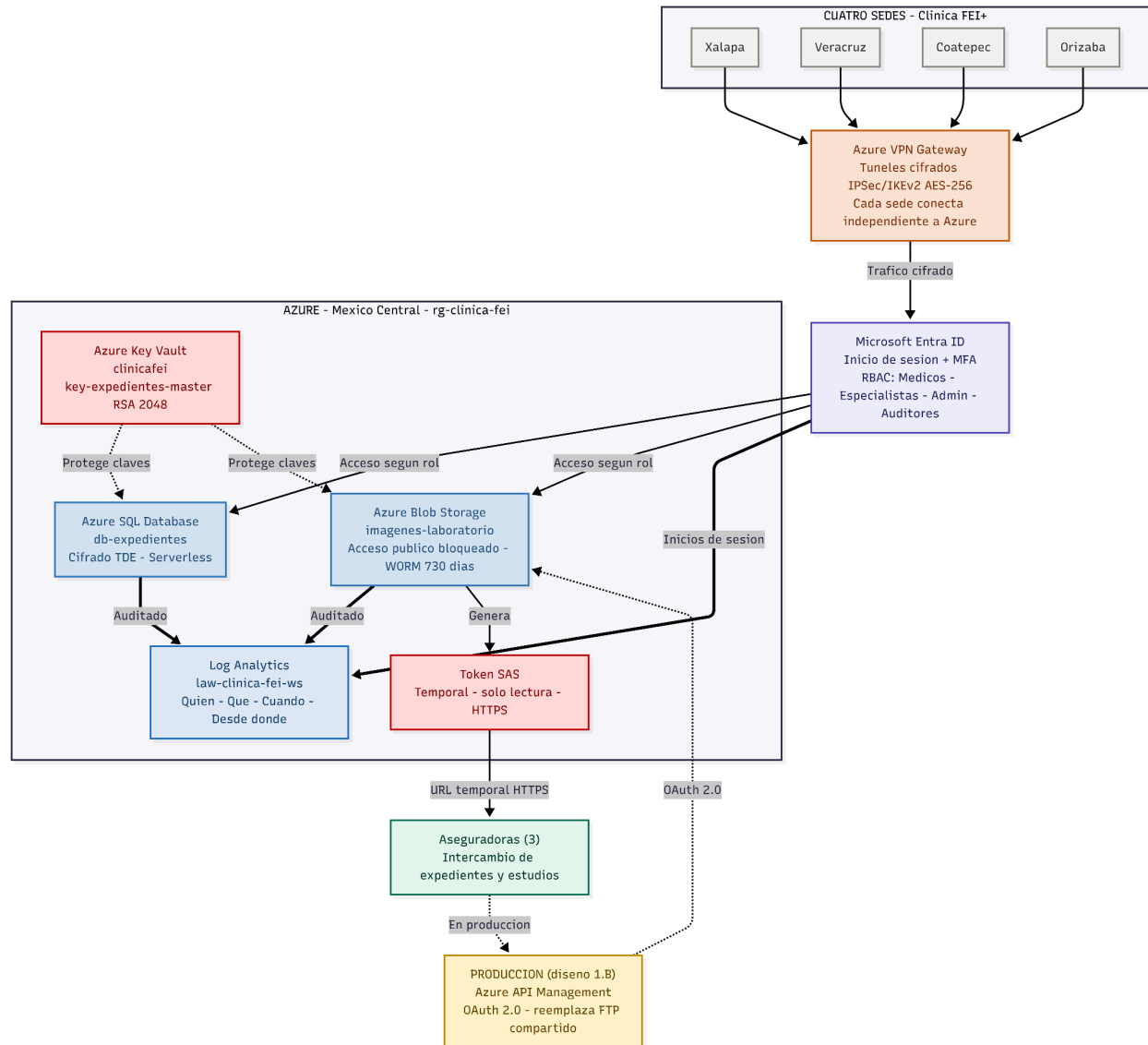
- Respaldos manuales.

Riesgos Prioritarios

Riesgo	Impacto	Prioridad
Exposición de expedientes clínicos	Muy Alto	Crítico
Ransomware	Muy Alto	Crítico
Acceso indebido a estudios médicos	Alto	Alto
Caída del servidor principal	Muy Alto	Alto
Robo de credenciales	Alto	Alto

4. Arquitectura Propuesta

La solución se implementó en la región Microsoft Azure México Central para cumplir con los requisitos de residencia de datos.



Los componentes principales son:

Microsoft Entra ID

Servicio utilizado para:

- Gestión de identidades.
- Autenticación multifactor (MFA).
- Control de acceso basado en roles (RBAC).

Roles definidos:

- Médicos.

- Especialistas.
 - Administradores.
 - Auditores.
-

Azure VPN Gateway

Diseñado para conectar las cuatro sedes mediante túneles VPN Site-to-Site cifrados utilizando:

- IPsec.
- IKEv2.
- AES-256.

Este componente elimina la transmisión de información en texto plano entre sedes.

Azure SQL Database

Utilizado para almacenar los expedientes clínicos.

Características implementadas:

- Transparent Data Encryption (TDE).
 - Servicio administrado (PaaS).
 - Escalabilidad automática.
 - RespalDOS automáticos.
-

Azure Blob Storage

Utilizado para almacenar:

- Estudios médicos.
- Resultados de laboratorio.
- Imágenes clínicas.

Configuraciones aplicadas:

- Acceso público deshabilitado.
- HTTPS obligatorio.

- Política WORM de 730 días.
-

Azure Key Vault

Servicio encargado de:

- Gestión de claves criptográficas.
- Protección de secretos.
- Administración centralizada de certificados.

Se implementó una clave maestra para proteger los recursos de almacenamiento y bases de datos.

Azure Log Analytics

Centraliza:

- Registros de auditoría.
- Eventos de autenticación.
- Operaciones administrativas.
- Accesos a recursos clínicos.

Permite responder:

- Quién accedió.
 - Qué realizó.
 - Cuándo ocurrió.
 - Desde dónde se realizó la operación.
-

5. Controles de Seguridad Implementados

Protección de Datos en Tránsito

Control implementado:

- VPN Site-to-Site con IPsec/IKEv2.

- HTTPS obligatorio.
- TLS para servicios expuestos.

Resultado:

Se elimina la transmisión de información clínica sin cifrado.

Protección de Datos en Reposo

Controles implementados:

- Transparent Data Encryption (TDE).
- Cifrado de Azure Storage.
- Protección de claves mediante Azure Key Vault.

Resultado:

La información permanece protegida incluso ante acceso físico no autorizado.

Control de Acceso

Controles implementados:

- Microsoft Entra ID.
- MFA.
- RBAC.

Resultado:

Los usuarios acceden únicamente a los recursos autorizados según su función.

Auditoría y Monitoreo

Controles implementados:

- Azure SQL Auditing.
- Azure Activity Logs.

- Azure Log Analytics.

Resultado:

Se garantiza trazabilidad completa sobre accesos y modificaciones.

6. Integración Segura con Aseguradoras

La infraestructura anterior utilizaba FTP con credenciales compartidas.

La solución implementada sustituye este mecanismo mediante:

Shared Access Signature (SAS)

Características:

- Acceso temporal.
- Permisos limitados.
- Comunicación HTTPS.
- Restricción por tiempo de expiración.

Beneficios:

- No se expone la red interna.
- Se elimina el uso de credenciales compartidas.
- Se aplica el principio de mínimo privilegio.

Evolución Propuesta

Para ambientes productivos se propone:

- Azure API Management.
 - OAuth 2.0.
 - Credenciales independientes para cada aseguradora.
-

7. Continuidad Operativa

La solución elimina la dependencia de un servidor físico único mediante servicios administrados de Azure.

Beneficios obtenidos:

- Disponibilidad del 99.99%.
- Réplicas automáticas.
- Recuperación ante fallos.
- Respaldos automáticos.
- Restauración a un punto en el tiempo.

Además, la arquitectura permite que cada sede opere de forma independiente, evitando que una falla local afecte a toda la organización.

8. Modelo de Responsabilidad Compartida

Control	Microsoft Azure	Clínica FEI+
Seguridad física	✓	
Infraestructura física	✓	
Virtualización	✓	
Gestión de usuarios		✓
Configuración RBAC		✓
MFA		✓
Clasificación de datos		✓
Gestión de expedientes		✓
Configuración de auditoría	Compartida	Compartida
Cifrado	Compartida	Compartida

9. Cumplimiento Regulatorio

LFPDPPP

La arquitectura contribuye al cumplimiento mediante:

- Protección de datos personales.
- Cifrado de información sensible.
- Control de acceso.
- Registro de actividades.

NOM-024-SSA3

La solución facilita:

- Integridad de expedientes clínicos.
 - Disponibilidad de información médica.
 - Trazabilidad de accesos.
 - Seguridad de los sistemas de información en salud.
-

10. Resultados Obtenidos

Los controles implementados permitieron resolver los tres hallazgos críticos identificados durante la auditoría:

Hallazgo	Solución Implementada	Estado
Datos sin cifrado	VPN + TLS + TDE	Resuelto
Falta de auditoría	Log Analytics + SQL Auditing	Resuelto
Acceso sin autenticación	Entra ID + MFA + RBAC	Resuelto

Asimismo, se implementaron controles adicionales relacionados con continuidad operativa, protección de datos y transferencia segura de información.

11. Conclusiones

La arquitectura implementada en Microsoft Azure proporciona una plataforma segura, escalable y alineada con los requisitos de negocio de Clínica FEI+. La solución permite proteger la información médica, garantizar la trazabilidad de las operaciones y mejorar significativamente la disponibilidad de los servicios.

Los controles implementados demuestran que es posible cumplir con los requerimientos de la auditoría utilizando servicios administrados en la nube, manteniendo un equilibrio entre seguridad, operación y costos. La propuesta establece además una base sólida para futuras ampliaciones y para una eventual migración completa a un entorno productivo.

12. Integrantes

- Turan Ozbek
- Abraham Nuñez Sanchez
- Rafael Alejandro Diaz Rangel
- Javier Patiño Gonzales